

Phase 6

API and Action Design

Preferred covered reading edition

APPROVED SCHEDULING AMENDMENT | PRESERVED REVIEW FOLLOWS

Read amendment first; underlying phase approval status is retained

Aesthenda Core Phase 6 Scheduling Amendment

Status: APPROVED DECISION PROPAGATION

Effective: September 7, 2026

This amendment applies DG-02, DG-03, and the approved overlap presentation to Phase 6. It controls conflicting scheduling language in the preserved review package; it does not grant new approval to unrelated material.

Fixed booking holds

All businesses use a fixed ten-minute booking hold, timed by the server from hold creation. There is no business, Service, or Appointment duration setting. Release early on explicit cancel/close; otherwise expire automatically. Confirmation revalidates the hold and current scheduling state; an expired hold cannot confirm from stale client state.

Professional overlap exceptions

Public booking never offers or confirms a non-fitting hands-on overlap. The authenticated owner-professional may manually book it after a specific warning and explicit confirmation bound to the exact request and current affected revisions. Published policy alone cannot authorize a hands-on conflict. Record the warning, actor, time, affected Appointments and segments, policy version, confirmation, and outcome. Preserve the full booked duration unless the professional explicitly edits it; never silently shorten work or move an existing appointment.

Minimal calendar presentation

Shade only the exact conflicting interval amber on both affected appointments, keeping their normal colors elsewhere. Show the same highlight while placing or moving the appointment, before the confirmation warning, and retain it after approval while the conflict exists. Use no persistent overlap label or extra icon. Tap or click reveals the overlap duration, affected appointments, and approval details. Provide the same details through keyboard interaction and screen-reader text without adding visible clutter.

Approved example

With zero buffers and other rules satisfied, a 10:00-10:15 application, 10:15-10:45 released processing segment, and 10:45-11:30 haircut permit a fitting 30-minute public service in the processing gap. A 45-minute service at 10:15 ends at 11:00 and is not offered publicly. A manual booking previews amber from 10:45 to 11:00 on both appointments, warns of the 15-minute overlap, and requires Book anyway before saving. Go back returns to editing without committing. Approval preserves the 45-minute booking and existing haircut timing.

Action contract effects

createBookingHold returns a server-derived expiry exactly ten minutes after creation for every business. It accepts no caller-chosen duration; retries do not restart an existing hold. releaseBookingHold retains early cancel/close behavior; confirmBooking rechecks expiry and fit transactionally.

calculateSlots and calculateOverlappingSlots never return the non-fitting hands-on conflict to a public caller. confirmBooking rejects it with PUBLIC_OVERLAP_NOT_ELIGIBLE; a caller-supplied override flag or published policy cannot bypass this result. Private appointment identities and exception evidence remain professional-only.

previewManualOverlap returns the eligible window, requested full duration/end, exact conflict interval and minutes, affected appointment/segment references and revisions, warning basis, and a request-bound confirmation token.

createManualOverlappingAppointment verifies professional authority, exact warning confirmation, token validity, and current revisions; it recomputes fit under the existing concurrency controls and persists appointment plus evidence atomically. Changed timing or affected revisions requires a fresh preview and confirmation. Apply the same requirements to moves and material edits that introduce or change a conflict.

Professional calendar results expose current conflict intervals and approved evidence for details on demand. Approval does not change a conflict into a conflict-free result. No persistent delegation or new autonomous agent override is introduced. The Phase Six approved handoff controls P6-D01 through P6-D10 status over the archived review decision table.

Verification requirements

Verify ten-minute holds across businesses, early release, stale expiry rejection, public omission/rejection of the 45-minute example, rejected unconfirmed manual save, accepted confirmed save, unchanged durations, and rejection of stale confirmation after a concurrent revision. Verify exact interval rendering before and after approval with details available on demand. These are design acceptance requirements; no application implementation is present in this document library.

Aesthenda Core — Phase Six Approved Decisions & Phase Seven Handoff

Approval outcome

All Phase Six approval decisions are resolved. This authorizes Phase Seven UI Blueprint work against the canonical action contracts. It does not authorize production implementation, endpoint deployment, vendor selection, production data processing, or launch.

Approved decisions

Decision	Approved direction
P6-D01: External transport	REST/JSON is the initial external transport. Canonical action contracts remain transport-neutral.
P6-D02: Action naming and versioning	Use verb–noun canonical action names, an action-version field, and compatibility/deprecation rules for breaking changes.
P6-D03: Overlap concurrency and warnings	Public booking blocks excess or non-fitting overlap. Professional exceptions require a clear warning, explicit confirmation, and complete audit evidence.
P6-D04: Client authentication	Use passwordless email or SMS links/codes by default; passkeys are optional for returning clients. A public booking session must be verified before confirmation, payment collection, or protected appointment access.
P6-D05: Professional step-up	Require fresh strong authentication and explicit confirmation for refunds, publication, retention/deletion, integration disconnect, and support break-glass. Use a narrow, short-lived, audited grant.
P6-D06: Public rate budgets	Platform-controlled, configurable limits and adaptive-abuse controls protect availability, holds, and verification. Business owners do not tune these safeguards.
P6-D07: Async status pattern	External or background work returns accepted/pending until final outcome. Provide a status resource, controlled polling, events/callbacks, and explicit timeout handling.
P6-D08: Error disclosure	Use privacy-first disclosure: hide protected-resource existence when needed; use permission-denied only when existence is safe to disclose; restrict support diagnostics to audited break-glass access.
P6-D09: Event compatibility	Standardize event envelopes and versioning, provide a consumer compatibility window, define replay authority, and assign dead-letter investigation/retry ownership.
P6-D10: Agent confirmations	Agents may answer questions, show published availability, and prepare drafts without confirmation. They must obtain explicit spoken or visual confirmation before any consequential action; no persistent delegation for consequential actions in v1.

Phase Seven handoff contract

Phase Seven UI work must:

- Call the approved canonical actions and render their structured states, warnings, errors, confirmations, and next_actions.
- Represent pending, failed, retry, expired, conflict, and permission states—not only happy paths.
- Request and communicate required client verification, professional step-up authentication, and agent confirmations at the correct points.

- Keep business logic in the canonical action layer. The UI must not create alternative slot calculations, payment truth, authorization rules, theme override fields, or database access paths.
- Respect account scope, privacy-first error disclosure, and all approved public anti-abuse controls.

Implementation boundary

The approved decisions are design requirements for the future implementation plan. Production implementation begins only after the appropriate authorization beyond Phase Six.

Approved scheduling decisions September 7 2026

Fixed booking holds

All businesses use a fixed ten-minute booking hold, timed by the server from hold creation. There is no business, Service, or Appointment duration setting. Release early on explicit cancel/close; otherwise expire automatically. Confirmation revalidates the hold and current scheduling state; an expired hold cannot confirm from stale client state.

Professional overlap exceptions

Public booking never offers or confirms a non-fitting hands-on overlap. The authenticated owner-professional may manually book it after a specific warning and explicit confirmation bound to the exact request and current affected revisions. Published policy alone cannot authorize a hands-on conflict. Record the warning, actor, time, affected Appointments and segments, policy version, confirmation, and outcome. Preserve the full booked duration unless the professional explicitly edits it; never silently shorten work or move an existing appointment.

Minimal calendar presentation

Shade only the exact conflicting interval amber on both affected appointments, keeping their normal colors elsewhere. Show the same highlight while placing or moving the appointment, before the confirmation warning, and retain it after approval while the conflict exists. Use no persistent overlap label or extra icon. Tap or click reveals the overlap duration, affected appointments, and approval details. Provide the same details through keyboard interaction and screen-reader text without adding visible clutter.

Approved example

With zero buffers and other rules satisfied, a 10:00-10:15 application, 10:15-10:45 released processing segment, and 10:45-11:30 haircut permit a fitting 30-minute public service in the processing gap. A 45-minute service at 10:15 ends at 11:00 and is not offered publicly. A manual booking previews amber from 10:45 to 11:00 on both appointments, warns of the 15-minute overlap, and requires Book anyway before saving. Go back returns to editing without committing. Approval preserves the 45-minute booking and existing haircut timing.

DG-02 Option A and DG-03 Option B are approved and binding on P6-D03, the hold actions, professional exception actions, and Phase Seven. See AESTHENDA_CORE_Phase_6_Scheduling_Amendment_v2.2.md for the propagated action contract and concurrency details.

Phase 6 API & Action Design

v2.2 REVIEW DRAFT

Purpose

Make one business action equal one controlled implementation that every web, mobile, voice, AI, and authorized integration surface can invoke without direct database access.

Governing scope	Design posture
Product	One independent beauty/wellness professional per business account; many clients; no v1 team, staff, front-desk, or multi-professional workflows.
Binding input	Approved Phase Five account isolation, time-segment scheduling, holds, payments, retention, recovery, support, webhook, and audit rules.
Architecture	Modular monolith; canonical action bus/services; PostgreSQL is private implementation infrastructure.
Status	APPROVAL-READY - P6-D03 approved; nine decisions remain; no production authorization.

Prepared under Aesthenda Core v2.2 Master Blueprint

September 1, 2026

1. Executive Summary

Canonical action rule

A consequential operation has one named action, one contract, one authorization and policy path, one transactional outcome, one audit record, and one event/outbox behavior - regardless of channel.

What Phase Six establishes

- **Action catalog:** commands and queries for authentication/account scope, clients, policies, availability, booking, appointments, payments, themes, notifications, integrations, and agents.
- **Execution envelope:** authenticate, resolve account, authorize capability, validate contract, load approved policy/version, enforce idempotency and concurrency, execute transactionally, audit, enqueue events, return structured response.
- **Channel neutrality:** web, mobile, voice, AI, and integrations adapt into the same contracts. No surface owns business rules or database access.
- **Safe boundaries:** scheduling owns time fit; payments own provider-linked financial state; themes own bounded publication; audit/outbox capture consequential facts.
- **Founder-readable contracts:** each action states purpose, actor, inputs, rules, outputs, errors, idempotency, audit, and events without prematurely fixing transport or vendor.

Approval meaning

Phase Six approval will authorize Phase Seven UI Blueprint work against these action contracts. It will not authorize production implementation, final endpoint/transport selection, vendor selection, launch, or production data processing.

2. Binding Phase Five Inputs

Area	Binding contract
Tenant & IDs	PostgreSQL baseline; composite business_account_id keys; FORCE RLS; UUIDv7/equivalent internal IDs; friendly references never authorize.
v1 professional model	One professional per business; many clients; no staff/team/front-desk/multi-professional assignment actions.
Scheduling	Timed service/appointment segments only; no stations, rooms, equipment, named/pool resources, or capacity actions.
Overlap	Professional configures maximum overlapping clients during eligible processing time. Public blocks limit excess or non-fit. Manual exceptions require clear warning, explicit confirmation, and recorded evidence.
Holds	Ten minutes; release immediately on client cancel/close, otherwise expire and reopen.
Payment terms	Professional configures deposit, full prepayment, no prepayment, or provider-held card on file; confirm only after required terms satisfied.
Retention	Client/booking/notes/messages: 3 years after last appointment then delete/anonymize unless hold. Payment/refund/audit: 7 years. Raw payment webhooks: 90 days then normalized evidence 7 years.
AI & support	AI transcripts only when needed for audit/support, redacted, 3 years, no secondary training. No default support access; consented, reasoned, short-lived, fully audited break-glass only.
Recovery	Future production requirement: maximum 1-hour RPO, maximum 4-hour RTO, continuous PITR, automated health checks, quarterly restore proof.
Overlap evidence	Record warning basis, actor, explicit confirmation, affected segments, policy version, and append-only audit for every professional manual exception.

3. Action Architecture and Channel Flow

Every channel is an adapter. It may shape presentation, speech, or integration payloads, but it cannot change the action meaning or bypass validation.

Layer	Responsibility	Forbidden
Channel adapter	Authenticate/session exchange; map surface input to canonical request; render structured result.	SQL, table knowledge, duplicated policy, hidden side effects.
Action gateway	Resolve action name/version, request metadata, actor, account scope, rate class, correlation and idempotency.	Trust caller account scope without verification.
Application action	Authorize, validate, load policy, coordinate module owners, transact, audit, emit.	Direct provider shortcuts or cross-module table writes.
Module owner	Scheduling, Payment, Policy, Theme, Client, Appointment, Notification, Integration, Audit/Outbox.	Write another module's tables.
Database/provider	Enforce constraints/RLS; perform provider-specific operation through boundary adapter.	Expose credentials/data plane to UI, voice, AI, or integrations.

Logical request flow

- Channel -> canonical action request -> trusted actor/account resolution -> capability authorization -> typed validation -> policy/version resolution -> idempotency/concurrency guard -> owning module transaction -> audit + outbox -> structured result.
- Queries follow the same authentication, account, permission, field-redaction, and rate controls but normally do not emit domain events.
- Provider callbacks enter through verified webhook intake, then invoke internal canonical actions; a webhook never writes payment or appointment tables directly.

4. Standard Action Contract

Contract field	Required meaning
Action identity	Stable verbNoun name, version, owning module, command/query classification, risk/rate class.
Actor context	actor_type, actor_id, authentication strength, granted capabilities, channel, agent/integration provenance.
Account context	Trusted business_account_id resolved server-side; requested resource IDs are validated inside it.
Request metadata	request_id, correlation_id, causation_id, idempotency_key when required, client/app version, locale.
Input	Typed fields, UUID/friendly-reference rules, field limits, expected_revision, dry_run/preview only when explicitly supported.
Preconditions	Required object state, policy version, hold/payment/consent state, provider connection, permission, time window.
Transaction	Owned records, locks, external-call boundary, commit point, compensating/retry behavior.
Output	Stable result schema: status, resource references, revision, warnings, next_actions, safe display facts.
Errors	Stable machine code, HTTP/transport mapping later, safe message, field details, retryable flag, correlation_id.
Evidence	Audit action/outcome/actor/target/policy versions; agent/integration provenance; before/after safe digests.
Events	Committed domain events and notification/outbox work; no event before database commit.
Retention	Classification and approved expiration/anonymization rule for request/evidence/transcript/raw callback data.

Response rule

A successful response means the canonical business transaction committed. Provider work explicitly modeled as asynchronous returns accepted/pending plus a status resource; it never pretends final success.

5. Authentication, Account Scope, and Authorization

Actor	Authentication	Authorization boundary
Professional owner	Authenticated business owner	All approved owner capabilities inside own account; manual overlap exception; policy/theme/payment settings; no other account.
Client	Authenticated/verified client or possession-bound booking session	Own booking/session/appointment actions explicitly exposed; never notes, audit, other clients, or business settings.
Public visitor	Anonymous session with anti-abuse controls	Published catalog/availability; start/continue booking; no protected record discovery.
Authorized integration	Connection identity + explicit scopes	Only named canonical actions for connected account; no generic read/write or SQL.
AI/voice agent	Invocation identity + initiating actor + narrow capability grant	Only allowlisted actions; confirmation gates for consequential operations; full provenance.
Background worker	Platform workload identity + event account context	Process named outbox/webhook/retention jobs; fail closed on context mismatch.
Support	No default access	Break-glass only after explicit professional consent, reason, short expiry, and full append-only audit.

Account-scope rules

- Caller-supplied `business_account_id` is never authoritative. Resolve it from session/connection/invocation; disagreement is denied and audited.
- Opaque IDs do not grant access. Every resource lookup uses trusted account scope and returns not-found/denied without cross-account disclosure.
- Step-up authentication or explicit confirmation is required for refunds, policy publication, booking-page publication, retention/deletion, integration disconnect, and break-glass support.

6. Validation, Errors, and Conflict Semantics

Code	Meaning	Recovery
AUTHENTICATION_REQUIRED	No valid actor/session; do not reveal target existence.	No
PERMISSION_DENIED	Actor lacks capability or confirmation/step-up.	No
ACCOUNT_SCOPE_MISMATCH	Trusted account and target/account context disagree.	No; security audit
VALIDATION_FAILED	Typed/field/business input invalid; include safe field details.	After correction
NOT_FOUND	Resource absent or intentionally undisclosed.	No
STATE_CONFLICT	Object state/revision changed; include current revision/next safe action.	After refresh
SLOT_UNAVAILABLE	Time no longer fits or hold expired.	Recalculate
PUBLIC_OVERLAP_NOT_ELIGIBLE	Full service does not fit eligible processing segment.	Professional manual action only
PUBLIC_OVERLAP_LIMIT_EXCEEDED	Proposed overlap exceeds the professional-configured maximum clients.	Professional manual action only
PAYMENT_TERMS_UNSATISFIED	Deposit/prepay/card-on-file requirement incomplete.	Complete terms
IDEMPOTENCY_CONFLICT	Same key used with different request hash.	New key after review
RATE_LIMITED	Actor/account/action budget exceeded; include retry_after.	Yes
PROVIDER_PENDING	External outcome not final; status resource supplied.	Poll/event
PROVIDER_UNAVAILABLE	Provider failed/timeout; no false final success.	Policy-based retry
INTERNAL_FAILURE	Safe generic message and correlation ID; no stack/secret.	Maybe

Error contract

- Errors are stable machine-readable contracts; human copy may change without breaking callers.
- Warnings never substitute for blocked invariants. A professional manual exception is a distinct authorized action, not an ignored error.
- Batch/multi-step results expose atomicity and per-item outcomes explicitly; partial success is never implied.

7. Idempotency, Concurrency, and Transaction Rules

Concern	Rule
Required idempotency	Appointment create/move/cancel, payment create/refund, publish, send/resend, integration callback normalization, retention/deletion jobs.
Key scope	business_account_id + action name + actor/connection class + idempotency_key; same request hash returns original result.
Conflict	Same key with changed input returns IDEMPOTENCY_CONFLICT; key cannot silently mutate prior work.
Optimistic concurrency	Updates carry expected_revision; stale requests return STATE_CONFLICT with safe current state.
Scheduling locks	Account/time-window scoped lock; re-evaluate availability, segments, and ten-minute hold at commit.
Provider boundary	Persist intent/idempotency before provider call; normalize callback later; reconcile unknown outcomes.
Commit/event rule	Business records, audit, and outbox insert commit together. Workers deliver after commit with dedupe/retry.

Ten-minute hold lifecycle

- createBookingHold starts a server-timed ten-minute hold after fresh slot calculation.
- cancelBookingSession or explicit client close releases immediately; otherwise expiration reopens automatically.
- confirmBooking rechecks hold, appointment state, consent, and professional-configured payment terms in one controlled flow.
- An expired hold never confirms from stale client state; return SLOT_UNAVAILABLE and recalculate.

8. Booking and Availability Actions

Action	Type	Actors	Contract intent
getPublishedBookingPage	query	public/client	Published services, safe theme, policy summaries, booking prerequisites.
calculateAvailableSlots	query	public/client/professional	Service version, date range, timezone; returns explainable slots and overlap eligibility.
calculateOverlappingSlots	query	public/professional	Public results only when full service fits and configured overlapping-client maximum is not exceeded; professional view may show warned exceptions.
startBookingSession	command	public/client	Create scoped session with source/channel and expiry.
createBookingHold	command	public/client	Reserve selected time for ten minutes; idempotent; recheck at commit.
releaseBookingHold	command	public/client/system	Release on cancel/close or system expiry; emit HoldReleased.
setBookingClient	command	client/public verified	Attach/create client under account using controlled matching/consent.
recordBookingConsent	command	client	Record exact consent/policy version and decision.
prepareBookingPayment	command	client	Return provider-safe next step for deposit/full/no-prepay/card-on-file policy.
confirmBooking	command	client/professional	Verify hold, time fit, consent, payment terms; create appointment and snapshot.
cancelBookingSession	command	client	Close session and release active hold immediately.

Public/manual overlap split

- Public adapters block when the full service does not fit the eligible processing window or the professional-configured maximum overlapping clients would be exceeded.
- Non-fit returns `PUBLIC_OVERLAP_NOT_ELIGIBLE`; limit excess returns `PUBLIC_OVERLAP_LIMIT_EXCEEDED`. Neither can confirm publicly.
- The professional uses `previewManualOverlap` then `createManualOverlappingAppointment`; saving requires a clear warning and exact-request confirmation. Record warning basis, actor, confirmation, affected segments, policy version, and audit evidence.

9. Professional Scheduling and Appointment Actions

Action	Type	Key behavior
getCalendar	query	Time range/status; account-scoped appointment projection with segments.
previewAppointmentChange	query	Move/service change; returns timing, policy, payment, communication, and warning impact.
createAppointment	command	Professional direct booking using canonical service/policy snapshot and time checks.
previewManualOverlap	query	Shows processing window, fit/overflow, current/configured overlap count, affected segments, and clear warning basis.
createManualOverlappingAppointment	command	Professional-only rule exception; require warning-bound explicit confirmation before save; persist complete evidence; idempotent.
moveAppointment	command	Expected revision; recheck segment fit; append prior/new snapshot and status event.
cancelAppointment	command	Apply cancellation policy; release time; coordinate refund/notification outcomes.
rescheduleAppointment	command	Controlled move plus client-facing confirmation; not cancel+unrelated create.
startAppointment	command	Transition scheduled/confirmed -> in_progress under valid state rules.
completeAppointment	command	Transition to completed; record safe completion facts; start last-appointment retention clock.
markNoShow	command	Professional-only state change under published policy.
addAppointmentNote	command	Encrypted, account-private note; approved 3-year retention; no AI training.

No resource actions in v1

There are no resource, station, room, equipment, pool, or capacity APIs. Scheduling actions operate only on professional time, availability, holds, and timed service/appointment segments.

10. Payment Actions

Action	Type	Contract intent
getPaymentPolicy	query	Return published deposit/full-prepay/no-prepay/card-on-file terms and safe client explanation.
previewPaymentRequirement	query	Calculate amount/status/next step for appointment/booking without provider mutation.
createPaymentOrder	command	Create idempotent Aesthenda intent linked to booking/appointment and policy version.
beginProviderPayment	command	Create/reuse provider intent through adapter; sensitive data stays provider-side.
recordCardOnFileReference	command	Store validated opaque provider reference only; never PAN/CVV/bank credentials.
refreshPaymentStatus	command/query	Reconcile provider status without treating client redirect as authoritative.
requestRefund	command	Professional + step-up; validate captured/refunded totals; provider idempotency; pending/final status.
processPaymentWebhook	internal command	Verify signature, dedupe, retain encrypted raw 90 days, normalize state/evidence for 7 years.
reconcilePayments	internal command	Compare Aesthenda/provider facts; add reconciliation evidence; never rewrite prior events.

Confirmation rule

- No-prepay: booking may confirm after all non-payment terms are satisfied.
- Deposit/full prepayment: confirm only after required provider success is canonicalized.
- Card on file: confirm only after a valid provider-held reference meets the published policy.
- Provider timeout/unknown: return pending or failure; do not claim confirmation unless policy requirements are satisfied.

11. Policy, Theme, and Client Actions

Action	Type	Actor	Contract intent
getPolicy / listPolicyVersions	query	Professional/client safe view	Versioned policy read; client receives only applicable published facts.
createPolicyDraft / updatePolicyDraft	command	Professional	Typed bounded draft; expected revision; no effect until publish.
validatePolicyDraft	query	Professional	Cross-rule errors/warnings, including configured maximum overlapping clients and manual-exception warning contract.
publishPolicyVersion	command	Professional + confirmation	Immutable effective version; audit/outbox; no retroactive appointment rewrite.
getThemeDraft / updateThemeDraft	query/command	Professional	Allowlisted colors, fonts, controlled sizing, safe asset references only.
previewBookingPage	query	Professional	Render draft with canonical core flow/facts protected.
publishBookingPage	command	Professional + confirmation	Atomic safe theme/publication bundle; audit/outbox; rollback point.
createClient / updateClient	command	Professional or booking flow	Account-local identity; validation/matching; expected revision.
mergeClients	command	Professional + preview/confirm	Same-account only; preserve booking/payment/audit history and mapping.
requestClientErasure	command	Client/professional authorized	Start hold-aware retention workflow; preview protected evidence.
executeRetentionAction	internal command	Worker	Apply 3/7-year rules idempotently; verify stores/index/cache; audit outcome.

12. Notifications and Integration Actions

Action	Type	Contract intent
previewCommunication	query	Render approved template with redacted preview and recipient/channel checks.
sendCommunication	command	Create canonical intent; idempotent; outbox delivery; content follows 3-year rule.
resendCommunication	command	New attempt linked to original; permission/rate controls; no duplicate hidden send.
recordDeliveryCallback	internal command	Verify/dedupe provider callback; append delivery fact; no appointment mutation.
connectIntegration	command	Professional + step-up; explicit scopes; provider auth through adapter.
updateIntegrationScopes	command	Professional + confirmation; least privilege; revoke removed scopes.
disconnectIntegration	command	Professional + confirmation; revoke secrets; stop future work; preserve required audit.
receiveIntegrationWebhook	internal command	Verify, account-map, dedupe, classify; then invoke a named internal canonical action.
syncIntegration	internal command	Checkpointed/account-scoped; bounded retries; external references never authorize.

Webhook lifecycle

- Raw payment webhook payloads are encrypted/restricted for 90 days, then securely deleted.
- Only necessary normalized payment/audit evidence remains for 7 years.
- Invalid signatures are quarantined/audited and never invoke business actions.
- A provider event ID is deduplicated within its connection; reordered events are normalized through legal transitions.

13. Agent and Voice Action Safety

Agent operation	Rule
startAgentInvocation	Create provenance: initiating actor, account, channel, agent/version, purpose, capability grant, expiry.
listAgentAvailableActions	Return only allowlisted actions and field constraints for current actor/account/context.
previewAgentAction	Run non-mutating validation/impact preview; redact protected fields beyond granted need.
confirmAgentAction	Bind human/professional confirmation to exact request hash, warnings, expiry, and actor.
executeAgentAction	Invoke the same canonical action as web/mobile; never a generic SQL/data tool.
endAgentInvocation	Record outcome/action references; store transcript only if audit/support need is declared.

Consequential-action confirmation

- Create/move/cancel appointment, manual overlap, refund, policy/theme publish, integration changes, deletion, and support access require explicit confirmation appropriate to actor/channel.
- Voice/AI confirmation repeats material facts: client, service, date/time/timezone, price/payment terms, policy effect, and overlap warning when applicable.
- Confirmation tokens are short-lived, single-use, request-hash bound, and invalid after underlying revision changes.
- AI transcript storage is opt-in by operational need only, redacted, retained 3 years, and never used for secondary training.

14. Audit, Events, and Outbox Contracts

Contract	Required content
AuditEvent	Append-only evidence of attempted/completed action: actor, account, target, policy versions, request/result digests, outcome, correlation.
AppointmentCreated/Changed/Cancelled	Committed appointment revision and safe snapshot refs; consumers fetch authorized projections.
BookingHoldCreated/Released/Expired	Hold reference, time window, reason, expiry; drives UX/cache cleanup.
PaymentOrderCreated/StatusChanged/RefundChanged	Normalized financial state/reference; never sensitive payment payload.
PolicyPublished/BookingPagePublished	Immutable version/publication refs; invalidates approved read models.
ClientRetentionDue/RetentionCompleted	Data-class scope, due basis, legal-hold result, counts/digests; no deleted plaintext.
CommunicationRequested/Delivered/Failed	Intent/attempt facts; content handled under approved retention and redaction.
IntegrationConnectionChanged	Scopes/status/actor; triggers worker cancellation or resync as appropriate.

Outbox behavior

- Insert event/outbox record in the same database transaction as the business change.
- Delivery is at-least-once; consumers deduplicate by event_id and handle order with aggregate revision/occurred_at.
- Retries use exponential backoff, bounded attempt policy, dead-letter/quarantine, operator visibility, and replay audit.
- Events contain minimum necessary data and account scope; they are not authorization tokens. Standard append-only audit evidence is retained 7 years.

15. Rate, Permission, and Abuse Expectations

Class	Expectation	Failure posture
Public availability	IP/session/account/service budgets; cache safe published projections; prevent date-range scraping.	429 RATE_LIMITED + retry_after; never leak private schedule.
Booking holds	Tight per session/client/account budgets; one active equivalent hold; bot/abuse controls.	Release abuse holds; audit patterns; do not punish legitimate professional action.
Authentication/verification	Progressive throttles by IP/identity/device; generic responses.	Avoid account enumeration; temporary challenge/lock.
Payments/refunds	Low limits, step-up, idempotency, provider limits, anomaly alerts.	No duplicate charge/refund; pending reconciliation.
Messages	Recipient/account/channel quotas, template/consent checks, unsubscribe/compliance.	Queue, throttle, or deny with reason.
Integrations/webhooks	Per connection/provider budgets; signature and event-size limits.	Backpressure/quarantine; no direct business write.
Agents/voice	Per invocation/action/cost budgets; allowlist; confirmation limits.	End invocation or require human confirmation.
Exports/retention/support	Rare, highly privileged, step-up, explicit reason and scope.	Async job with audit; no unrestricted synchronous dump.

Permission inventory

Each action has one machine-readable permission descriptor: allowed actor types, required capability, authentication strength, confirmation requirement, account scope, field redaction, rate class, idempotency requirement, and audit severity. CI fails if a new action lacks the descriptor.

16. Representative Action Contracts

confirmBooking v1

Field	Contract
Actor	Client/public verified session or professional; trusted business account resolved server-side.
Input	booking_session_id, hold_id, expected revisions, client/consent refs, payment order/provider status ref, idempotency_key.
Rules	Hold active; fresh segment fit; public overlap fully fits and stays at/below configured maximum clients; published service/policy/payment versions; required terms satisfied.
Commit	Appointment + segments + snapshot + status + overlap decision + audit + outbox; consume hold.
Output	confirmed appointment ref/friendly ref, revision, time/timezone, payment state, next actions.
Errors	SLOT_UNAVAILABLE, PUBLIC_OVERLAP_NOT_ELIGIBLE, PUBLIC_OVERLAP_LIMIT_EXCEEDED, PAYMENT_TERMS_UNSATISFIED, STATE_CONFLICT, IDEMPOTENCY_CONFLICT.

createManualOverlappingAppointment v1

Field	Contract
Actor	Authenticated professional owner only; explicit confirmation required.
Input	client, service_version, start/timezone, preview token/request hash, explicit warning confirmation, idempotency_key.
Rules	Recompute fit and overlap count; when outside normal rules, show clear warning and reject save without exact-request professional confirmation.
Commit	Appointment/snapshot/segments + warning basis + actor + confirmation + affected segments + policy version + append-only audit/outbox.
Output	appointment ref/revision, recorded warning/confirmation evidence, affected segments, communication next action.

17. Contract and Security Test Matrix

ID	Test	Required proof
ACT-01	Channel equivalence	Same action/input/actor through web, mobile, voice, AI, integration yields equivalent rule/result/evidence.
ACT-02	No direct data access	Surface and agent credentials cannot connect/query database; integration webhook cannot write modules.
ACT-03	Tenant isolation	Foreign-account IDs fail for every action/query without disclosure; RLS/composite keys backstop.
ACT-04	Permission descriptor	Every action has actor/capability/auth/confirmation/rate/idempotency/audit metadata.
ACT-05	Idempotency	Duplicate identical command returns original; changed hash conflicts; provider retry never duplicates charge/refund.
ACT-06	Concurrency	Stale revision and scheduling races fail/retry safely; only one final state commits.
ACT-07	Public overlap	Only full-fit overlap at/below professional-configured maximum appears/confirms; non-fit or excess is automatically blocked.
ACT-08	Manual overlap	Outside-rule add shows clear warning, cannot save without exact confirmation, and records basis/actor/confirmation/segments/audit.
ACT-09	Hold lifecycle	Ten-minute server expiry; cancel/close early release; stale confirmation rejected.
ACT-10	Payment terms	All four professional modes gate confirmation correctly; provider unknown never becomes success.
ACT-11	Events/outbox	No pre-commit event; at-least-once dedupe/order/replay/dead-letter behavior proven.
ACT-12	Retention	3/7-year and 90-day jobs, holds, cache/search/object deletion, AI redaction/no-training provenance proven.
ACT-13	Support	No default access; consent/reason/expiry/audit required; expired grant denied.
ACT-14	Recovery contract	Future implementation exposes health/restore evidence proving <=1h RPO and <=4h RTO; draft does not claim deployment.
ACT-15	Errors	Stable safe codes, no secrets/stacks/cross-account existence, retry semantics consistent.

Exit criteria

- All canonical actions contract-tested against the production database engine/migrations before implementation approval.
- Negative tests cover public, client, professional, integration, agent, worker, and support contexts.
- Schema/action inventory diff fails when a table mutation lacks an owning action or an action bypasses its module owner.

18. Phase Six Approval Decision Log

Decision / status	Topic	Approved baseline or approval question
P6-D01	External transport	Approve REST/JSON as initial external transport, another transport, or defer while preserving transport-neutral action contracts.
P6-D02	Action naming/versioning	Approve verbNoun canonical names, action version field, compatibility/deprecation window, and breaking-change policy.
P6-D03 - APPROVED	Overlap concurrency/warnings	Professional configures maximum overlapping clients. Public blocks excess/non-fit. Manual exception shows a clear warning, requires explicit confirmation, and records basis, actor, confirmation, affected segments, and audit.
P6-D04	Client authentication	Approve passwordless/link/code/passkey posture and when a public booking session must become verified.
P6-D05	Professional step-up	Approve which consequential actions require recent strong authentication and confirmation lifetime.
P6-D06	Public rate budgets	Approve starting availability/hold/verification thresholds and adaptive-abuse policy; values remain configurable.
P6-D07	Async status pattern	Approve accepted/pending status resources, polling limits, callback/event expectations, and timeout UX.
P6-D08	Error disclosure	Approve not-found vs permission-denied disclosure posture for clients/integrations and support diagnostics.
P6-D09	Event compatibility	Approve event envelope/versioning, consumer compatibility window, replay authority, and dead-letter ownership.
P6-D10	Agent confirmations	Approve exact actions and facts requiring spoken/visual confirmation and whether any can be delegated persistently.

Approval readiness

P6-D03 is approved and fully reflected in the action contracts. Nine Phase Six decisions remain for review; discuss P6-D04 authentication, P6-D05 step-up, P6-D01 transport, and P6-D02 versioning first.

19. Blueprint Deliverables Traceability

Required deliverable	Location	Status
Action catalog	Sections 8-13	Canonical booking, scheduling, appointment, payment, policy, theme, client, notification, integration, agent actions.
Request/response schemas	Sections 4 and 16	Standard envelope and representative full contracts; per-action schemas follow approved decisions.
Authorization matrix	Section 5	Actor types, trusted account scope, capabilities, confirmation and support posture.
Error taxonomy	Section 6	Stable safe machine codes, conflict and recovery behavior.
Idempotency rules	Section 7	Scope, hashes, duplicates, conflicts, provider boundary, concurrency.
Version/compatibility policy	Sections 4 and 18	Action version is required; final transport/version window pending P6-D01/D02.
Webhook/event contracts	Sections 12 and 14	Verified intake, 90-day raw lifecycle, normalized events, outbox, retries/dedupe/replay.
API examples/contract tests	Sections 16-17	Representative contracts and fifteen acceptance tests.

Phase Seven handoff contract

- UI flows call these canonical actions and render their structured states, warnings, errors, confirmations, and next_actions.
- UI never creates alternate business rules, payment truth, slot math, theme override fields, or database paths.
- Screen design must represent pending/failed/retry/expired/conflict/permission states, not only happy paths.
- No production endpoint or implementation begins from Phase Six approval alone.

20. Phase 6 Approval Gate

STATUS: APPROVAL-READY - P6-D03 APPROVED; NINE DECISIONS REMAIN

Approval questions

- Can every consequential operation be invoked by web, mobile, voice, AI, or an authorized integration through one canonical action without duplicated logic or direct database access?
- Does every command authenticate, resolve trusted account scope, authorize capability, validate, apply approved policy, enforce idempotency/concurrency, transact, audit, emit, and return a stable structured result?
- Does public booking automatically block overlap that exceeds the professional-configured maximum clients or whose full service does not fit the eligible processing window?
- Does a professional manual exception show a clear warning, require explicit confirmation before save, and record warning basis, actor, confirmation, affected segments, and audit evidence?
- Do ten-minute holds and all four professional payment modes gate confirmation correctly under retries, provider delays, and races?
- Are errors, warnings, pending states, permission disclosures, rate expectations, and confirmations safe and understandable across channels?
- Are integrations, webhooks, workers, support, and agents constrained to least-privilege named actions with complete provenance?
- Do action/evidence contracts enforce approved 3/7-year retention, 90-day raw webhooks, AI redaction/no-training, standard append-only audit, and future recovery proof?
- Are the nine remaining Phase Six decisions in Section 18 approved or explicitly deferred without creating hidden behavior?

Approval effect

Approving Phase Six authorizes Phase Seven UI Blueprint work against these canonical action contracts. It does not authorize production implementation, endpoint deployment, vendor selection, production data processing, Phase Eight design-system approval, or launch.

Final review gate

Can every consequential operation be safely invoked by UI, mobile, AI, voice, or an authorized integration without duplicating or bypassing Aesthenda's booking, policy, payment, client, audit, or account-isolation logic?